

Clase 333 — kali-mcp: orquestar herramientas de Kali desde un agente de IA

Parte: **18 — IA aplicada a la ciberseguridad** · Fuente: **kali-mcp** de pabperez (licencia MIT) — <https://github.com/pabperez/kali-mcp> ⌚ Duración estimada: **120 min** · Nivel: **Avanzado**

⚠ **Uso ético y legal.** kali-mcp automatiza herramientas ofensivas. Úsalo **solo** contra sistemas propios (tus VMs de laboratorio) o con **autorización explícita por escrito**. Que la IA lo haga más rápido no lo hace legal: la autorización y la responsabilidad son tuyas.

Objetivo

Montar y entender **kali-mcp**, un servidor MCP (de código abierto, MIT) que conecta un agente de IA con más de 50 herramientas de Kali Linux dentro de un contenedor Docker. Verás su arquitectura y el flujo de trabajo `/kali-start` → `/kali-pentest` → `/kali-finish`, siempre con supervisión humana y contra un objetivo autorizado de tu laboratorio.

Esta clase **explica y referencia** kali-mcp con atribución a su autor; el contenido aquí es original. Consulta el repositorio oficial para la documentación y los comandos exactos.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

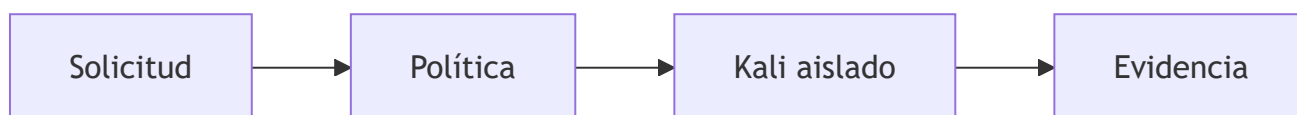
1. **Describir** la arquitectura de kali-mcp: agente ↔ gateway MCP ↔ contenedor Kali.
2. **Instalar** kali-mcp en un laboratorio propio con Docker.
3. **Definir** el alcance (scope) de una sesión antes de actuar.
4. **Ejecutar** un flujo supervisado y entender qué hace cada comando de alto nivel.
5. **Aplicar** los controles: aislamiento, aprobación humana y trazabilidad.

Temas

#	Tema	Por qué importa
1	Arquitectura de tres capas	Agente, gateway MCP y contenedor Kali aislado.
2	Instalación con Docker	Reproducibile y aislada del host.
3	Definición de alcance	<code>/kali-start</code> fija qué está permitido tocar.
4	Orquestación (<code>/kali-pentest</code>)	La IA coordina varias herramientas/sub-agentes.
5	Cierre e informe (<code>/kali-finish</code>)	Consolida hallazgos en un reporte.
6	Controles de seguridad	Aislamiento, aprobación y logs de cada acción.

Explicación en profundidad

Orquestar Kali concentra autoridad: parámetros generados pueden escanear, modificar o exfiltrar. La arquitectura limita comandos, destinos, credenciales, red, tiempo y salida; un contenedor no basta si posee red o sockets privilegiados.



El diagrama separa lenguaje de autoridad. El modelo puede proponer; la política determina si la operación pertenece al alcance; la herramienta produce evidencia; y una persona o control determinista decide transiciones de alto impacto. Se registran prompt relevante, parámetros validados, versión, salida, aprobador y cleanup sin almacenar secretos innecesarios.

Caso razonado

El agente propone un rango fuera del contrato. El broker rechaza el destino antes de que la herramienta lo reciba.

Glosario operativo

Término	Definición
Broker de herramientas	Capa que valida y media cada ejecución.
Guardrail	Capa que reduce una capacidad o detecta su uso; no garantía absoluta.
Audit trail	Registro ordenado de solicitudes, decisiones, ejecuciones y resultados.

Criterio de dominio

El alumno demuestra dominio cuando reproduce el flujo completo, puede atribuir cada acción, evita que texto no confiable otorgue autoridad y explica qué control contiene un fallo del modelo.

Definiciones y características

kali-mcp : Proyecto MIT que expone las herramientas de Kali a un agente de IA vía MCP. Característica clave: las herramientas corren en un **contenedor Docker aislado**, no en tu host.

Gateway MCP : Componente que traduce las peticiones del protocolo MCP en ejecuciones de herramientas dentro del contenedor y devuelve los resultados al agente.

Comando de flujo (/kali-start , /kali-pentest , /kali-finish) : Playbooks de alto nivel que definen alcance, orquestan el análisis y compilan el informe, respectivamente.

Alcance (scope) : Conjunto de objetivos e IPs/dominios que la sesión tiene permitido tocar. Debe corresponder a tu autorización real.

Herramientas y preparación

- **Docker y Docker Compose** (clase 022) y un cliente de IA con MCP (p. ej. Claude Code).
- Un **objetivo autorizado propio**: una VM vulnerable de tu laboratorio (p. ej. el [lab appsec-web](#) o una VM tipo Metasploitable en red aislada).
- Sigue las instrucciones oficiales del repositorio para la instalación exacta.

Laboratorio guiado

Todo contra un objetivo **tuyo** en una red **aislada**. Nunca contra Internet.

1. **Clonar e inicializar** (según el README oficial del proyecto):

```
bash git clone https://github.com/pabpereza/kali-mcp.git cd kali-mcp ./init.sh # levanta el contenedor Kali y el gateway MCP
```

2. **Conectar el agente.** Configura tu cliente de IA para usar el servidor MCP de kali-mcp (archivo de configuración `.mcp.json` del proyecto).
3. **Definir alcance.** Ejecuta el flujo de inicio y declara **solo** la IP de tu VM de laboratorio como objetivo autorizado.
4. **Observar, no delegar a ciegas.** Pide un reconocimiento y **revisa** cada herramienta que el agente propone antes de aprobar acciones activas.
5. **Cerrar.** Genera el informe de la sesión y compáralo con lo que observaste: ¿los hallazgos son reales y verificables?
6. **Aislamiento.** Confirma que el contenedor no tiene acceso a redes fuera de tu laboratorio.

Ejercicios

1. Dibuja la arquitectura de kali-mcp e indica dónde está el aislamiento.
2. ¿Por qué es importante que las herramientas corran en un contenedor y no en tu host?
3. Define el alcance correcto para un lab con una sola VM objetivo.
4. Enumera 3 acciones que exigirías aprobar manualmente aunque el agente las proponga.
5. ¿Cómo verificarías que un hallazgo del informe no es una alucinación?

Reto verificable

Monta kali-mcp contra una VM vulnerable **de tu propiedad** y ejecuta un flujo de reconocimiento supervisado, terminando con un informe.

Criterio de aceptación: el alcance se limitó a tu VM; aprobaste manualmente las acciones activas; el informe lista hallazgos que puedes **reproducir manualmente** con la herramienta correspondiente (no confías ciegamente en la IA).

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El contenedor no arranca / healthcheck falla	Revisa Docker y los issues del repo; consulta <code>docs/</code> del proyecto.
El agente propone tocar IPs fuera de alcance	Corta y redefine el scope; nunca amplíes a objetivos no autorizados.
Hallazgos que no puedes reproducir	Posible alucinación o mala interpretación. Verifica a mano antes de reportar.
El contenedor tiene salida a Internet	Aíslalo; un lab ofensivo no debe poder alcanzar terceros.
Ejecutar <code>/kali-pentest</code> sin leer qué hace	Entiende cada fase; tú eres responsable de las acciones.

Preguntas frecuentes

? ¿Es legal usar kali-mcp? La herramienta sí (es MIT y educativa). Lo que puede ser ilegal es **usarla contra objetivos sin autorización**. Limitate a tus sistemas o a engagements con permiso escrito.

? ¿La IA "hackea sola"? No. Propone y ejecuta herramientas, pero tú defines el alcance, apruebas las acciones y validas los resultados. Es un copiloto, no un piloto automático.

? ¿Reemplaza aprender las herramientas? No. Si no sabes qué hace `nmap` o `sqlmap`, no podrás validar ni corregir al agente. La IA amplifica tu criterio; no lo sustituye.

Referencias

- **kali-mcp (MIT)** — <https://github.com/pabpereza/kali-mcp> (documentación y comandos oficiales).
- [Model Context Protocol](#)
- [Lab: pentest asistido por IA con MCP](#) del programa.
- [Catálogo de playbooks de kali-mcp mapeados al curso](#).

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 332 — Agentes de IA y el Model Context Protocol \(MCP\) para seguridad](#)

Siguiente clase

[Clase 334 — Reconocimiento y escaneo asistidos por IA](#)